WKMS OWASP Top 10 Security Evidence

Evidence updated 25 October 2026 | WKMS subsystem | PR #53 / DDP-79

Review status: evidence-based, not a penetration-test sign-off

Developer test runs and GitHub CI support discrete security controls; none of these observations amount to production OWASP compliance certification.

Control	Status	Evidence / gap
A01 Broken Access Control	PARTIAL	JWT worker-role/active-account validation and task ownership regression. Route-wide authorization matrix pending.
A02 Cryptographic Failures	PARTIAL	Signed short-lived JWT accepted; invalid JWT rejected. Production TLS and key-rotation policy not verified.
A03 Injection	PARTIAL	Parameterized repository queries previously reviewed; comprehensive injection/fuzz tests not recorded.
A04 Insecure Design	PARTIAL	Persistence-before-broadcast, idempotency and failure tests. No signed threat model.
A05 Security Misconfiguration	PARTIAL	Local socket auth/CORS; deployed WSS origin checks, TLS and secrets policy require review.
A06 Vulnerable Components	PARTIAL	Backend/frontend npm production audits report 0; other build/deploy supply-chain exposure not fully assessed.
A07 Authentication Failures	PARTIAL	Live valid demo_worker and invalid JWT handshakes tested; password login and session revocation end-to-end not checked in this snapshot.
A08 Integrity Failures	PARTIAL	Lockfiles, test evidence and GitHub Actions success at PR SHA; signing/provenance not verified.
A09 Logging and Monitoring	PARTIAL	Failure-handling logs and suppression of sensitive event payloads tested; alerting and log retention not verified.
A10 SSRF	NOT VERIFIED	No dedicated outbound destination allowlist/SSRF test evidenced.

Key updates after DDP-79

Valid demo_worker Socket.IO connection passed against real backend. Production npm audits returned 0 vulnerabilities in both frontend and backend. PR #53 CI run passed on the verified head SHA. Peer approval, production WSS infrastructure, full new-code coverage and live fanout remain pending.